Cyber Deception Chronicles

Social Engineering Attacks & Major Security Breaches



ALA-3 | DETIT15214 - Cryptography and Network Security

Gohil Priyrajsinh | Enrollment No: 241105060045 | Batch B22

Sem 5, Class B | Gyanmanjari Innovative University

Three Ways Attackers Hack the Human



Phishing

HOW IT WORKS

Fake emails or messages that mimic a trusted sender to steal logins or install malware.

EXAMPLE

A "password expired" email linking to a cloned login page.

Red flag: Urgent tone plus an unexpected link or attachment



Pretexting

HOW IT WORKS

The attacker invents a believable story and identity so the victim hands over information.

EXAMPLE

A caller posing as IT support asking for a password reset code.

Red flag: Requests that skip normal verification steps



Baiting

HOW IT WORKS

Tempts the victim with something free or curious that hides malware.

EXAMPLE

USB drives labelled "Salary 2026" dropped in a car park.

Red flag: Too-good-to-be-true offers or unknown devices

Anatomy of a Social Engineering Attack



Research

Gather names and roles from LinkedIn and websites



Hook

Contact the victim by email, call or SMS



Manipulate

Use urgency, fear or authority to pressure



Exploit

Victim shares credentials or runs malware



Impact

Data theft, fraud or ransomware

~60%

of breaches involve the human element (Verizon DBIR 2025)

Psychological triggers attackers exploit

- Urgency
- Authority
- Fear
- Helpfulness

Case Studies I: Twitter 2020 & RSA 2011

2020

Twitter Bitcoin Hack

Vishing / phone spear-phishing

Researched staff and remote-work setup → Phoned employees posing as IT support → Stole credentials for internal admin tools → Hijacked famous accounts for a crypto scam

Impact: High-profile accounts hijacked; Bitcoin scam took in over $100,000.

Prevented by: FIDO2 security keys, least-privilege tools, two-person approval.

2011

RSA SecurID Breach

Spear-phishing + zero-day

Emailed small groups of RSA staff → Opened an Excel file named "Recruitment Plan" → Flash zero-day installed a backdoor → SecurID-related data stolen

Impact: SecurID data stolen; EMC reported ~$66M in remediation costs.

Prevented by: Attachment sandboxing, fast patching, phishing drills.

Case Studies II: Target 2013 & MGM 2023

2013

Target Data Breach

Third-party credential theft

Phished HVAC vendor Fazio Mechanical → Stole the vendor's network login → Moved on to the payment network → Installed malware on POS systems

Impact: ~40M payment cards and ~70M customer records exposed.

Prevented by: Network segmentation, vendor MFA, acting on security alerts.

2023

MGM Resorts Attack

Vishing / help-desk impersonation

Found employee details on LinkedIn → Called the IT help desk as that employee → Got credentials and MFA reset → Deployed ransomware, systems down

Impact: Hotel and casino systems down for days; ~$100M estimated cost.

Prevented by: Strict ID checks for resets, call-backs, phishing-resistant MFA.

Defence in Depth: Stopping the Human Hack



Awareness Training

Regular phishing simulations and short drills so staff spot the red flags.



Phishing-Resistant MFA

Security keys and passkeys mean a stolen password is not enough.



Verify Out-of-Band

Call back on a known number before sharing data or resetting access.



Least Privilege

Limit access and segment networks so one account cannot open every door.



Filter & Monitor

Email filtering, attachment sandboxing and alerts someone acts on.



Report Fast

A no-blame culture where reporting a suspicious message is one click.

Key Takeaways

1. Humans are the first target, and the first line of defence.
2. Every case here succeeded by tricking people, not by breaking encryption.
3. Verification, MFA and least privilege stop most social engineering.

Sources: Twitter Inc. incident report (2020); NYDFS Twitter investigation report (2020); RSA "Anatomy of an Attack" blog (2011); US Senate Commerce Committee report on the Target breach (2014); MGM Resorts SEC Form 8-K (2023); Verizon Data Breach Investigations Report 2025.